

RESEARCH pki_pq_nat

RESEARCH pki_pq_nat

Revision: 1 Last modified: 2026-07-04T12:00:00Z

Scope: Device enrollment + PKI, post-quantum WireGuard handshake, WireGuard NAT traversal / DERP relay / Tailscale coordination + 4via6, for a Mullvad-parity self-hosted VPN spec. All facts cited; access date 2026-06-25.

1. Device enrollment + PKI

1.1 WireGuard's native identity model (baseline)

- WireGuard uses **one Curve25519 keypair per device**; the **public key IS the device identity**. Access is granted by adding a peer's public key to the server/peer config. [Contabo, VyOS]
- **Revocation is structurally trivial**: remove the public key from the peer set and the device is instantly cut off — no CRL/OCSP needed. A unique keypair per device makes revocation a single-line config change; keygen takes seconds. [Contabo blog]
- WireGuard has **no built-in PKI/cert lifecycle**: no CA, no cert expiry, no CRL/OCSP, no enrollment protocol. If you need cert lifecycle control, granular revocation, and compliance mapping, that layer must be built *around* WireGuard (the OpenVPN TLS/PKI model has it natively; WireGuard does not). [Contabo blog]
- Practical enrollment paths in the wild: QR-code provisioning and MDM push for mobile/edge fleets. [Contabo blog]

1.2 Recommended PKI architecture: layer SPIFFE/SPIRE-style short-lived mTLS over WG

The Mullvad-parity pattern is a **coordination/control plane** that issues short-lived device credentials and pushes WG public keys to peers. SPIFFE/SPIRE is the canonical 2025 reference for this two-identity split:

- **Two device identities** (the key design pattern):
 1. a **long-lived device attestation cert** ("I am a genuine enrolled device", optionally TPM/Secure-Enclave-bound), and
 2. a **short-lived SVID** ("I am authorised to access this service right now"). [axelspire SPIFFE device-fleet article]
- **Short-lived X.509-SVID / JWT-SVID**: default TTL **1 hour**, configurable down to minutes, **automatically rotated by the agent before expiry**. 2025 best-practice guidance: keep SVID TTL **≤ 60 min for hot paths**. [SPIRE docs; debugg.ai; spletzer.com]
- Identity is a **structured URI bound to attestable properties at issuance** (not IP, not hostname) — SPIRE attests the workload/device at runtime and delivers per-workload short-lived keys+certs over the Workload API for mTLS. [spiffe.io use-cases; SPIRE docs]
- **Revocation propagation**: with short TTLs, revocation is largely "stop renewing" — the credential self-expires within the TTL window (minutes), avoiding CRL/OCSP distribution latency. This is the dominant 2025 model: identity becomes "a verifiable, short-lived property" rather than a static secret. [debugg.ai; petronellatech]

1.3 Design implication for the spec (per-device WG keypair on device)

- **Generate the WG private key ON the device**; never transmit it. The control plane only ever receives the **public key** during enrollment, binds it to the short-lived device cert/SVID, and distributes it to authorized peers.
 - **Tenant CA** issues the device attestation cert; the coordination server mints/rotates the short-lived mTLS cert the device uses to call the control API. Revocation = (a) stop renewing the short-lived cert (self-expiry) AND (b) remove the WG public key from the peer set (instant dataplane cutoff) — belt-and-suspenders.
-

2. Post-quantum WireGuard handshake

2.1 The PSK-injection approach (Mullvad / Rosenpass pattern)

- Vanilla WireGuard's handshake (Noise IK, Curve25519) is **not PQ-secure** and is vulnerable to **harvest-now-decrypt-later (HNDL)**.
- The deployed mitigation everyone uses is WireGuard's **pre-shared key (PSK)** feature: a separate PQ key-exchange derives a PSK that is mixed into the WG handshake. WireGuard's own crypto is unchanged, so it is "cryptographically no less secure than WireGuard on its own" plus PQ protection. [Rosenpass README]
- **Hybrid, not PQ-only**: production deployments combine a classical KEM and a PQ KEM so the result is no weaker than either. This is the standing recommendation (hybrid until PQ primitives are battle-tested). [Mullvad blog; pq-wireguard analysis]

2.2 Mullvad — production status (parity target)

- Mullvad exchanges a **PQ-secure PSK for WireGuard**; algorithms currently used: **Classic McEliece + ML-KEM**. [Mullvad blog]
- **Quantum-resistant tunnels are the DEFAULT on desktop as of 2025-01-09**. [Mullvad blog "now the default on desktop"]
- **Mobile**: post-quantum launched for iOS/iPhone (TechRadar). The embedded Rosenpass-server PSK auto-rotation path is still marked **experimental and not yet supported on mobile** in the agent. [Mullvad; TechRadar]
- Mullvad **embeds a Rosenpass server in its agent (since agent v0.25.4)**, auto-rotating PSKs on all peer-to-peer connections. [search synthesis]
- Open-source reference implementation: **mullvad/wgephemeralpeer** — PQ-secure WireGuard PSK exchange for vanilla WireGuard + custom integrations (use this as the build template). [github.com/mullvad/wgephemeralpeer]
- Mullvad migrated Kyber→**ML-KEM** (CEO: "As Kyber now has been updated (ML-KEM) we are planning to migrate to this"). [Mullvad / synthesis]

2.3 Rosenpass — current facts

- Formally-/symbolically-analysed PQ add-on for WireGuard, **written in Rust**; performs a PQ key exchange and hands the result to WireGuard via the **PSK feature, refreshing the symmetric key every 2 minutes**. [Rosenpass README]

- KEMs: **Classic McEliece** (authenticity/confidentiality, "store-now decrypt- later" protection via a NIST-approved primitive) + **Kyber-512** (forward secrecy/confidentiality). Uses **liboqs**. [HN/Rosenpass; README]
- **Verification status**: NOT a full cryptographic proof yet — provides a **symbolic analysis using ProVerif** (./analyze.sh); a cryptographic security proof is "in progress". [Rosenpass README]
- **Latest release: v0.2.2 (2024-06-05)** at time of fetch; repo actively maintained. (Note: still Kyber-512, not yet ML-KEM in the tagged release — verify upstream before relying on ML-KEM in Rosenpass specifically.) [github.com/rosenpass/rosenpass]

2.4 Standards anchor

- **FIPS 203 (ML-KEM)** published by NIST **2024-08-13**; specifies Module- Lattice KEM. **NSA CNSA 2.0** requires ML-KEM for key encapsulation on national security systems; migration windows began 2025. [QuantumXchange FIPS-203]
 - Spec guidance: target **hybrid X25519 + ML-KEM-768** for the classical+PQ KEM, optionally + Classic McEliece for the McEliece-strength HNDL guarantee (Mullvad-parity = McEliece + ML-KEM). Keep it as a **PSK feed into WG**, do not fork the WG handshake.
-

3. NAT traversal / hole punching / DERP relay / coordination

3.1 WireGuard + NAT traversal core (Tailscale model)

- Architecture favors **direct peer-to-peer** WG; a coordination server + **DERP relays** handle connection setup and fallback. Vast majority of traffic goes direct. [Tailscale DERP docs]
- **STUN** discovers each peer's public IP:port mapping; the coordination layer gets both peers to send packets **simultaneously** so each NAT records an outbound flow and permits the return ("**UDP hole punching**"). Works for **~94%** of NAT configurations / "direct >90% of the time". [Tailscale NAT blog]
- **UDP foundation**: NAT traversal is built on UDP (TCP adds complexity). Firewall remembers the outbound packet and admits the matching inbound even if the original outbound was dropped. [Tailscale how-NAT-traversal-works]

- **ICE-style:** "try everything at once, pick the best that works" — probe all candidate endpoints, transparently upgrade to the best path mid-session. [Tailscale]

3.2 Symmetric ("hard") NAT — the hard case

- **Symmetric NAT** randomizes the source-port mapping per destination, so the far side can't predict the port → usually needs a relay. Two peers both behind hard NAT almost always relay. [sitepoint; Tailscale]
- **Birthday-paradox** probe for one-side-symmetric: open 256 ports while peer random-probes → **50% success ~2 s, 98% within ~20 s @100 pkt/s. Dual symmetric NAT ~28 min** for 99.9% → impractical, relay instead. [Tailscale]
- Port-mapping helpers reduce one NAT layer: **UPnP-IGD, NAT-PMP, PCP**. Hairpinning support is inconsistent (complicates CGNAT P2P). [Tailscale]

3.3 DERP relay (the fallback + signaling channel)

- **DERP = Detoured Encrypted Routing Protocol**, a general packet-relay protocol that **runs over HTTP/HTTPS**. Two roles: (1) connection-setup **signaling channel**, (2) **last-resort relay** when hole punching fails. [Tailscale]
- **DERP never decrypts:** relays are "dumb pipes for ciphertext" — they forward WG-encrypted packets, preserving end-to-end encryption. Slower but guarantees *some* connectivity always. [sitepoint; Tailscale DERP docs]
- **Peer Relays (introduced Oct 2025):** designate your OWN tailnet nodes as dedicated relays instead of "DERP roulette" — relevant for self-hosted parity (run your own relay fleet). Headscale supports self-hosted/custom DERP maps. [Tailscale peer-relays blog; Headscale DERP docs]

3.4 4via6 — overlapping/duplicate CIDR overlay

- **4via6** lets you connect **hundreds/thousands of identical (overlapping-CIDR) IPv4 networks** without renumbering, by mapping each site's IPv4 route into a **unique IPv6 prefix** (the IPv6 address encodes a **site ID + the IPv4 address**). [Tailscale 4via6 docs/blog]
- Generate the route via CLI: `tailscale debug via <site-id> <ipv4-route>`. **Site ID = lower 16 bits only, range 0-65535**. [Tailscale 4via6 docs]
- **ACLs must target the IPv6 CIDR/address** as destination, not the IPv4. Two 4via6 subnet routers are used when ranges overlap to prevent conflicts. **Requires Tailscale v1.24+** on the subnet router (clients reaching it can be older). [Tailscale 4via6 docs; schema.ai insight]

- Use case for the spec: multi-tenant / many-identical-VPC connectivity with overlapping RFC1918 space — 4via6 is the clean overlay answer.
-

Sources verified

- <https://contabo.com/blog/wireguard-vs-openvpn-a-deep-dive-protocol-comparison/> — accessed 2026-06-25
- <https://docs.vyos.io/en/latest/configuration/interfaces/wireguard.html> — accessed 2026-06-25
- <https://spiffe.io/docs/latest/spire-about/use-cases/> — accessed 2026-06-25
- <https://axelspire.com/business/device-identity-spiffe-workload/> — accessed 2026-06-25
- <https://debugg.ai/resources/goodbye-service-api-keys-spiffe-spiffe-workload-identity-zero-trust-mtls-kubernetes-multi-cloud-2025> — accessed 2026-06-25
- <https://www.spletzer.com/2025/03/zero-to-trusted-spiffe-and-spiffe-demystified/> — accessed 2026-06-25
- <https://petronellatech.com/blog/machine-identity-is-the-new-perimeter-mtls-spiffe-for-zero-trust/> — accessed 2026-06-25
- <https://mullvad.net/en/blog/quantum-resistant-tunnels-are-now-the-default-on-desktop> — accessed 2026-06-25
- <https://mullvad.net/en/blog/experimental-post-quantum-safe-vpn-tunnels> — accessed 2026-06-25
- <https://github.com/mullvad/wgephemeralpeer> — accessed 2026-06-25
- <https://www.techradar.com/pro/vpn/mullvad-launches-post-quantum-protection-for-iphones> — accessed 2026-06-25
- <https://github.com/rosenpass/rosenpass> — accessed 2026-06-25
- <https://news.ycombinator.com/item?id=34969760> — accessed 2026-06-25
- <https://thomwiggers.nl/publications/pq-wireguard/> — accessed 2026-06-25
- <https://quantumxc.com/fips-203-validated-pqc/> — accessed 2026-06-25
- <https://tailscale.com/blog/how-nat-traversal-works> — accessed 2026-06-25
- <https://tailscale.com/blog/nat-traversal-improvements-pt-1> — accessed 2026-06-25
- <https://tailscale.com/docs/reference/derp-servers> — accessed 2026-06-25
- <https://www.sitepoint.com/tailscale-peer-relays-nat-traversal-derp/> — accessed 2026-06-25
- <https://tailscale.com/blog/peer-relays-international-networks> — accessed 2026-06-25
- <https://headscales.net/stable/ref/derp/> — accessed 2026-06-25

- <https://tailscale.com/docs/features/subnet-routers/4via6-subnets> — accessed 2026-06-25
- <https://tailscale.com/blog/4via6-connectivity-to-edge-devices> — accessed 2026-06-25
- <https://schema.ai/technologies/tailscale/insights/4via6-requires-ipv6-destinations> — accessed 2026-06-25